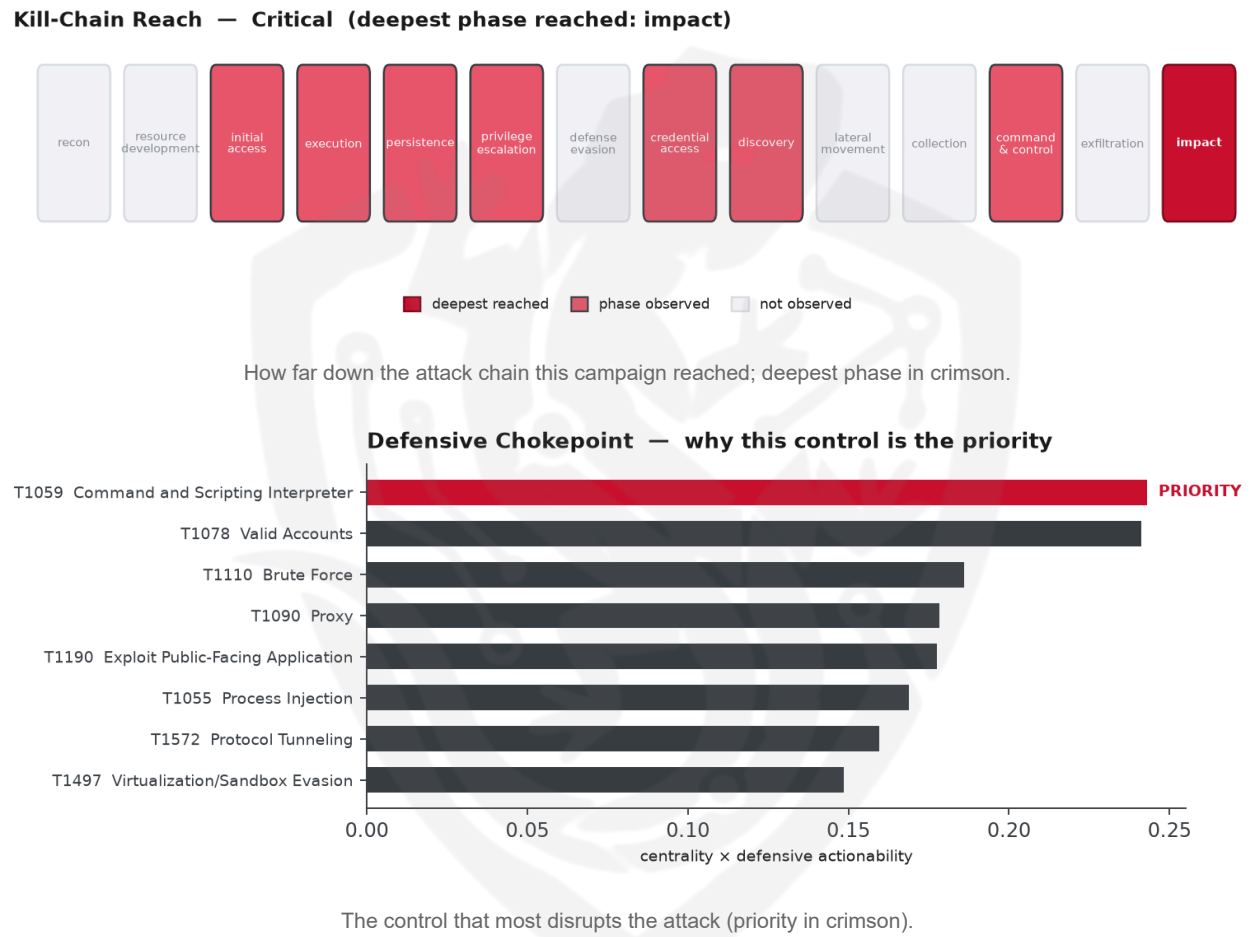


THREAT REPORT: UNKNOWN_ADVERSARY - RUSTDUCK BOTNET

Visual Summary



Summary

The observed cluster of activity, attributed to an unknown threat actor, has been linked to the RustDuck malware family, which exploits the CVE-2025-29635 vulnerability. The targeted country and sectors are currently unknown. Priority should be given to patching the CVE-2025-29635 vulnerability on all affected systems to mitigate the threat. Additionally, constraining PowerShell for unprivileged users and enabling script-block logging are crucial defensive actions.

Threat Overview

The threat actor, referred to here as the observed cluster of activity, utilizes the RustDuck malware family to exploit the CVE-2025-29635 vulnerability. The victimology of this campaign is currently unknown, but the techniques employed by the malware suggest a sophisticated attack chain. The malware family is

known to exploit multiple vulnerabilities, including CVE-2017-17215, CVE-2018-8007, CVE-2024-1781, and CVE-2025-29635.

Attack Chain and Priority Control

The observed techniques employed by the RustDuck malware family form a complex attack chain, involving system information discovery, application layer protocol manipulation, and exploit public-facing application exploitation. The priority technique in this chain is T1059 Command and Scripting Interpreter, which serves as a critical chokepoint. To mitigate this threat, the following concrete control is recommended: Patch CVE-2025-29635 on all affected systems as the top priority, then: Constrain PowerShell for unprivileged users (Constrained Language Mode + AppLocker); enable script-block logging; block wscript/cscript where unneeded.

Infrastructure and Corroboration

The RustDuck malware family has been corroborated by abuse.ch to be associated with other malware families, such as Gafgyt and Mirai. However, no hosting providers or ASNs have been observed, and AbuseIPDB has not flagged any indicators with a confidence level of 80% or higher. The highest AbuseIPDB confidence seen is 0%, indicating a lack of reputation flags for the observed indicators.

Technical Appendix

Ground-truth telemetry from the source pulse; analytical scores are secondary and clearly labelled.

Observed Techniques (ATT&CK, expert-tagged by source)

- T1082 System Information Discovery
- T1071 Application Layer Protocol
- T1140 Deobfuscate/Decode Files or Information
- T1190 Exploit Public-Facing Application
- T1036 Masquerading
- T1055 Process Injection
- T1572 Protocol Tunneling
- T1016 System Network Configuration Discovery
- T1090 Proxy
- T1059 Command and Scripting Interpreter
- T1083 File and Directory Discovery
- T1497 Virtualization/Sandbox Evasion
- T1057 Process Discovery
- T1110 Brute Force
- T1078 Valid Accounts
- T1027 Obfuscated Files or Information
- T1573 Encrypted Channel
- T1203 Exploitation for Client Execution

- T1498 Network Denial of Service
- T1105 Ingress Tool Transfer

Analytical Scores

- Priority technique (graph chokepoint): T1059 Command and Scripting Interpreter (centrality 0.3037).
- Operational risk: Critical (score 1.0, reaches impact).

Behavioral Signature Cluster

- Method: technique-overlap cosine vs 170 MITRE ATT&CK Groups (top overlap 0.4602; reference threshold $\tau = 0.6$).
- These are behavioural resemblances for defensive playbook cross-referencing, not an identity assessment. Where the source pulse names an actor, that attribution is authoritative; the overlaps below neither confirm nor contest it.

Nearest historical profiles by behavioural overlap (resemblance only):

Historical Profile	Behavioural Overlap
Darkhotel	0.4602
Tropic Trooper	0.4183
Higaisa	0.3841
APT18	0.3689
Inception	0.3451

Enrichment Signal

- Highest AbuseIPDB confidence among IOCs: 0%.
- Malware families corroborated by abuse.ch: Gafgyt, Mirai.
- Note: enrichment raises the severity signal (an IOC at or above 80% AbuseIPDB confidence, or a confirmed malware-family hit). This is context, not a change to the source assessment.

Indicators of Compromise (defanged — non-clickable)

The network and file indicators observed in this activity are listed below for blocklisting:

Type	Indicator	Context
Domain	disciplinenahidwin[.]jst	Mirai
Domain	igmc[.]duckdns[.]org	malware_download

Type	Indicator	Context
Domain	criminalcloudflare[.]online	
Domain	bigniggadick[.]ignorelist[.]com	
Domain	dhdsjsdjc[.]duckdns[.]org	
Domain	fcfrfxrfsfs5f[.]duckdns[.]org	
Domain	gayporn[.]twilightparadox[.]com	
Domain	ilovefemboy[.]mooo[.]com	
Domain	qewqewqewqtq[.]duckdns[.]org	
Domain	qewqewqewqtqthree[.]duckdns[.]org	
Domain	qewqewqewqtqtwo[.]duckdns[.]org	
Hash	b519ae088ee0fd4658c16aab474d51c6acdc5c9cd7fab3fd69032d05a45ffd9b	Gafgyt
Hash	4d11bd496da82d15b3ed13050f414e44f5a892d4	Gafgyt
Hash	6aa791c76b3107fca9d57b7ecea8f46d97d83738	
Hash	8315f650e9e4f67c00277b076ab304eed23db47d	Gafgyt
Hash	d39a3ee96be6b8f5238cb1253514ab55c88f714c	
Hash	36e51d11e70c04c60a9c3a4f088ed507	Gafgyt
Hash	9d864a76a4f6dc1d26febd34856c0509	Gafgyt
Hash	a5d1b65b1055677156cd87b357ef488704115a2cbf52044dbb041072efed2f9d	Gafgyt

Reputation by AbuseIPDB · malware attribution by abuse.ch · Geo/ASN data by IP2Location LITE.